

Enterprise AI Authentication Research • Part 6 of 7

Part 6

Banking Case Study

Production architecture for a highly regulated bank: Zero Trust AI agents with AWS, Entra ID, MCP, GitHub Enterprise, ServiceNow, Confluence, Jira, M365, SharePoint, and Slack

Enterprise Authentication & Identity Propagation for AI Agents

Case Study — Regulated Banking Institution

This case study designs a production-grade enterprise AI platform for a global bank subject to SOC 2, ISO 27001, PCI DSS, NIST SP 800-63, and financial regulations including MAS TRM, FCA SYSC, and SOX. The architecture prioritises identity traceability, least-privilege access, human oversight for privileged actions, and complete audit trails.

Bank Technology Stack

- Cloud: AWS (primary), with M365 SaaS for productivity
- Identity Provider: Microsoft Entra ID (primary) + legacy ADFS federation
- AI Runtime: AWS Bedrock AgentCore + MCP servers + A2A for agent orchestration
- Source Code: GitHub Enterprise (GHES) — on-premises
- ITSM: ServiceNow (SaaS)
- Knowledge: Confluence (Data Center on-prem) + SharePoint Online
- Project Tracking: Jira (Data Center on-prem)
- Productivity: Microsoft 365 (Exchange, Teams, OneDrive)
- Communication: Slack Enterprise Grid
- Authorization Policy Engine: Open Policy Agent (OPA) with Rego
- SIEM: Splunk Enterprise Security

Architecture Layers

Banking Architecture Layers

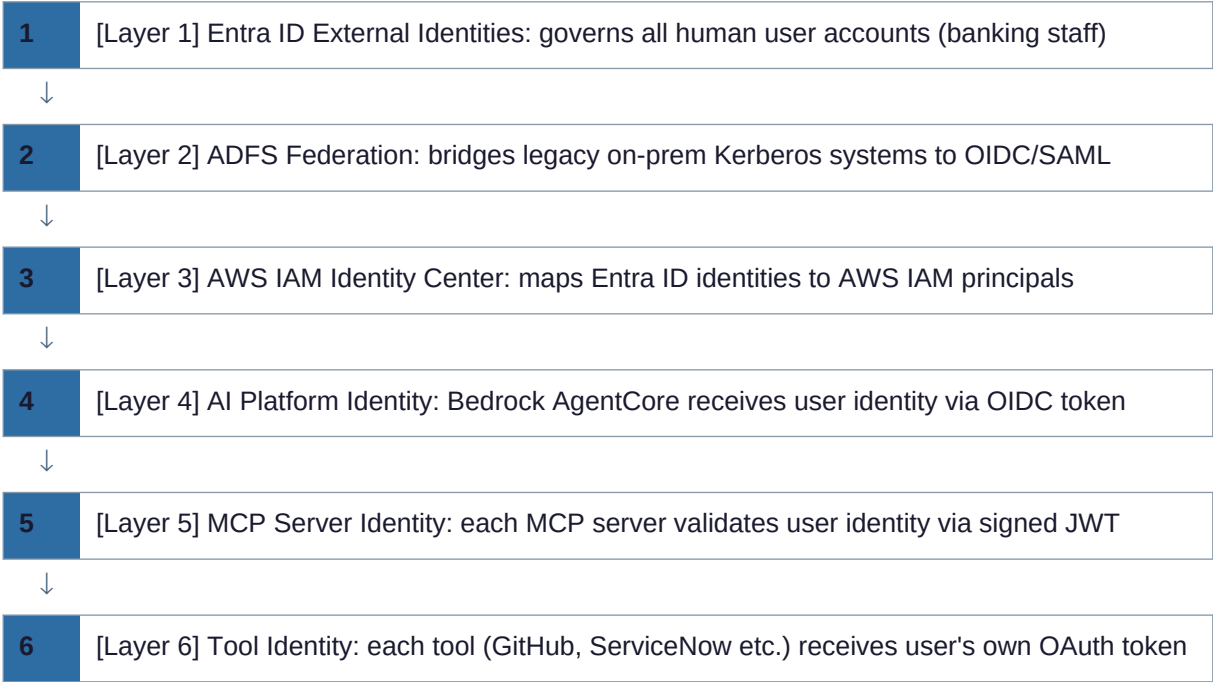
Layer	Component	Purpose
Identity & Authentication	Entra ID + ADFS + AWS IAM Identity Center	Single source of truth for user identity; SSO across all systems
AI Orchestration	AWS Bedrock AgentCore + Claude via Bedrock	Managed agent runtime; VPC-isolated; IAM-controlled
Tool Gateway (MCP)	MCP Server Gateway (AWS ECS + ALB)	Centralised MCP server registry; enforces auth + audit per tool
Tool Connectors	Per-system MCP servers (GitHub, SN, Confluence, etc.)	Each connector handles its own OAuth; returns structured data
Policy Engine	OPA (Open Policy Agent) sidecar	Fine-grained authorization before and after LLM decisions
Secrets Management	AWS Secrets Manager + HashiCorp Vault	Encrypted storage for OAuth tokens, refresh tokens, API keys
Audit & Compliance	Splunk ES + AWS CloudTrail + M365 Purview	Centralised, correlated, tamper-evident audit chain

Layer	Component	Purpose
Human Oversight	ServiceNow Approval Workflows + Slack approval bots	Required approval gate for privileged AI actions

Identity Architecture

Multi-Layer Identity Stack

Banking Identity Stack — 6 Layers



ADFS Federation Bridge

The bank's ADFS (Active Directory Federation Services) infrastructure federates on-premises Active Directory to Microsoft Entra ID. Modern cloud services (AWS, Slack, ServiceNow SaaS) authenticate via Entra ID SAML/OIDC endpoints. Legacy on-prem systems (Confluence DC, Jira DC, GHES) continue to use Kerberos or LDAP, with identity bridged via ADFS.

Identity Integration by System

System	Auth Protocol	Identity Source	MFA Enforced By
M365 / Copilot	OIDC → Entra ID	Entra ID	Entra Conditional Access
AWS Bedrock / Q	SAML → IAM Identity Center	Entra ID via ADFS	Entra CA + IAM condition
ServiceNow SaaS	SAML 2.0 → Entra ID	Entra ID	Entra Conditional Access
Slack Enterprise	SAML 2.0 → Entra ID	Entra ID	Entra Conditional Access
GitHub Enterprise (GHES)	SAML SSO → Entra ID	Entra ID via ADFS	Entra CA (EMU recommended)

System	Auth Protocol	Identity Source	MFA Enforced By
Confluence DC (on-prem)	Kerberos / LDAP	Active Directory	AD-integrated MFA (ADFS)
Jira DC (on-prem)	Kerberos / LDAP	Active Directory	AD-integrated MFA (ADFS)

OAuth 2.1 and OBO Implementation

The bank standardises on OAuth 2.1 for all new integrations. OAuth 2.1 consolidates security best practices from OAuth 2.0 RFCs: PKCE is mandatory, implicit flow is prohibited, and refresh token rotation is required. On-Behalf-Of (RFC 8693) is used wherever the AI agent needs to call downstream APIs preserving user identity.

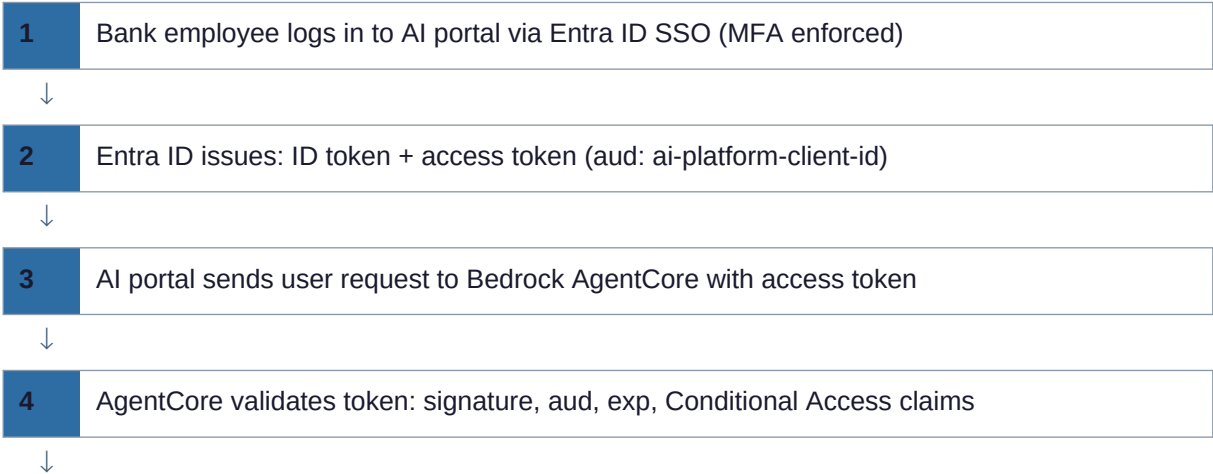
OAuth 2.1 Requirements Checklist

OAuth 2.1 vs 2.0 Requirements

Requirement	OAuth 2.0	OAuth 2.1	Bank Implementation
PKCE	Optional (recommended)	MANDATORY	Enforced at Entra ID authorization server
Implicit Flow	Allowed	PROHIBITED	Blocked by Entra ID app registration settings
Resource Owner Password	Allowed	PROHIBITED	Service principle policy blocks ROPC grants
Refresh Token Rotation	Optional	REQUIRED	All refresh tokens rotate on use (Entra default)
Exact Redirect URI matching	Approximate OK	EXACT MATCH REQUIRED	App registrations use exact URI only
Bearer token in URL query	Allowed (not recommended)	PROHIBITED	API gateway rejects tokens in query string

Complete OBO Chain — User → Bedrock → MCP → GitHub

Bank OBO Chain — 13 Steps





Fine-Grained Authorization with OPA

The bank deploys Open Policy Agent (OPA) as a sidecar to the MCP Server Gateway. Every tool call passes through OPA before execution. Rego policies encode the bank's authorization rules, including data classification checks, business hours restrictions, and privileged action approval requirements.

Sample OPA Rego Policy — GitHub Tool Authorization

```
package bank.ai.github

default allow := false

# Allow read operations for authenticated bank employees
allow if {
  input.tool == "read_pr"
  input.user.department in {"engineering", "devops", "security"}
  input.token.scope[_] == "github:read_pr"
  not is_blocked_repo(input.args.repo)
}

# Block access to repos tagged as PCI-scoped
is_blocked_repo(repo) if {
  data.repos[repo].classification == "PCI_CDE"
  input.user.clearance != "PCI_AUTHORIZED"
}

# Require approval for write operations
allow if {
  input.tool == "create_pr"
  input.user.department == "engineering"
  input.approval.status == "APPROVED"
  input.approval.approver_role == "tech_lead"
}
```

OPA Decision Points in the AI Workflow

OPA Decision Points

Decision Point	OPA Input	Policy Checks	On Deny
User accesses AI portal	User identity, device health, location	Is user enabled? Is device compliant? Is location allowed?	Redirect to Entra ID Conditional Access denial page
AI selects a tool	User identity, tool name, conversation context	Is tool allowed for this user's role? Is it business hours?	Tool removed from LLM's available tools; LLM informed

Decision Point	OPA Input	Policy Checks	On Deny
Tool call execution	User identity, tool args, data classification	Does user have clearance for data in request?	Tool call blocked; user notified; audit event raised
Privileged action	User identity, action type, approval chain	Has action been approved by required approver?	Action deferred; approval request sent to ServiceNow
Tool response delivery	Response content, data classification labels	Does response contain data user shouldn't see?	Response redacted; Splunk alert raised

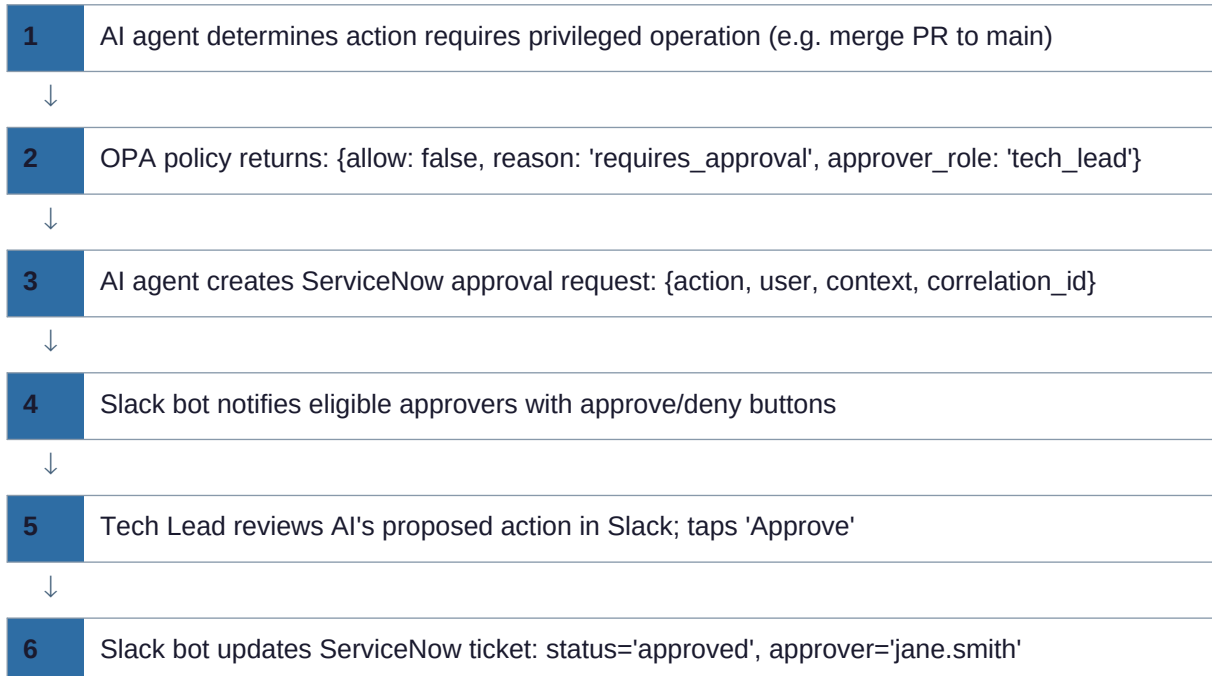
Human-in-the-Loop for Privileged Actions

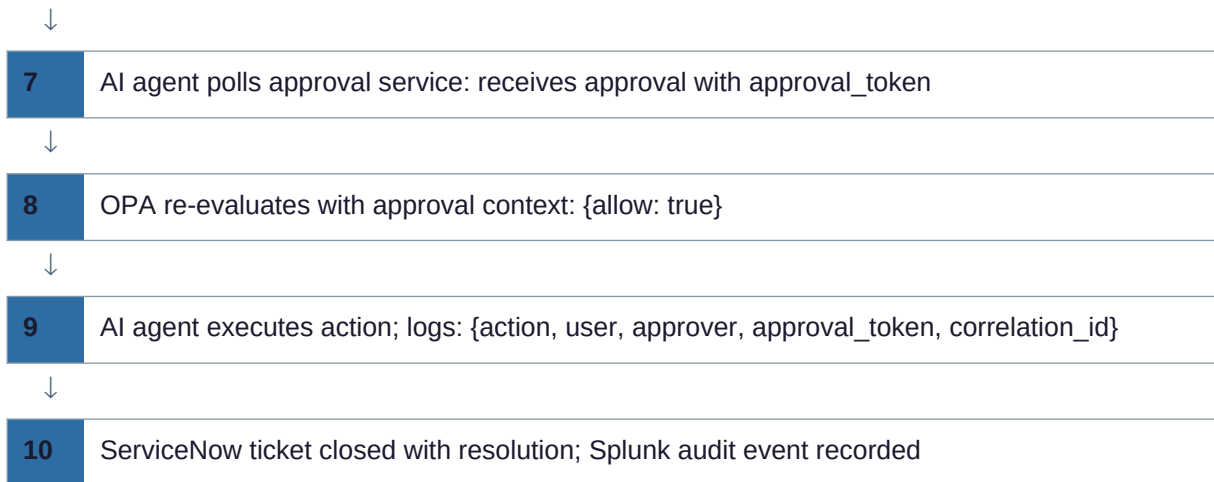
The bank requires human approval before AI agents execute any privileged action — defined as any action that creates, modifies, or deletes production data, or any action that could affect regulatory-controlled systems (PCI, SOX scope).

Privileged Action Approval Requirements

Action Category	Examples	Approver	Approval Channel	SLA
Code changes	Create PR, merge PR, deploy	Senior Engineer / Tech Lead	Slack approval bot	30 minutes
ITSM changes	Create change request, close incident	Change Advisory Board (CAB)	ServiceNow approval workflow	2 hours
Data access (PCI)	Query cardholder data environment	CISO or delegate	ServiceNow + email	1 hour
User access changes	Provision access, modify permissions	IAM team	ServiceNow catalog task	4 hours
External communications	Send email to external parties	Compliance officer	Slack approval bot	1 hour
Financial data modification	Update cost centre, budget records	CFO delegate	ServiceNow + audit log	2 hours

Human Approval Workflow — 10 Steps





Compliance Framework Mapping

Compliance Framework to Architecture Control Mapping

Framework	Key AI-Relevant Requirements	Architecture Control	Evidence
SOC 2 (Security)	CC6: Logical access controls; CC7: System monitoring	Entra ID CA; OPA authz; Splunk SIEM	Entra audit logs; OPA decision log; Splunk alerts
SOC 2 (Availability)	A1: System availability and performance	AWS multi-AZ Bedrock; MCP HA; health checks	AWS CloudWatch SLA metrics
ISO 27001 A.9	Access control policy; user access management	RBAC/ABAC via OPA; SCIM provisioning	Entra ID access reviews; OPA policy log
PCI DSS 7	Restrict access to system components to need-to-know	OPA PCI-scope isolation; no AI access to CDE without approval	OPA deny logs for PCI tools; ServiceNow approval chain
PCI DSS 10	Log and monitor all access to network resources and cardholder data	CloudTrail + Splunk for all AI-to-PCI-system calls	Splunk search: index=ai_audit pci_scope=true
NIST SP 800-63 AAL2	Multi-factor authentication for regulated systems	Entra CA enforces MFA before AI portal access	Entra sign-in logs showing MFA satisfied
SOX (ITGC)	Change management; access controls; audit trail	Human approval for code/data changes; complete audit chain	ServiceNow change records; GitHub audit log; Splunk

Zero Trust Posture Summary

Zero Trust Maturity Assessment

Zero Trust Pillar	Bank Implementation	Maturity Level
Identity	Entra ID with MFA + Conditional Access + CAE; SCIM provisioning	Advanced
Devices	Intune-managed devices required for AI portal access (CA policy)	Intermediate
Network	VPC isolation for MCP servers; PrivateLink for on-prem connectors; no public MCP endpoints	Advanced
Applications	OPA sidecar on every MCP call; no implicit app-to-app trust	Advanced

Zero Trust Pillar	Bank Implementation	Maturity Level
Data	Purview sensitivity labels on M365 data; OPA data classification checks	Intermediate
Infrastructure	AWS IAM roles (no static keys); STS short-term credentials; GuardDuty	Advanced
Visibility	Splunk ES with AI-specific detections; CloudTrail; real-time anomaly alerts	Advanced

Common Anti-Patterns to Avoid

Banking AI Architecture Anti-Patterns

Anti-Pattern	Risk	Correct Pattern
Shared service account for all AI tool calls	No user-level attribution; any action shows as 'ai-service-account' in audit	Per-user OAuth tokens via OBO; each action attributed to actual user
Long-lived API keys for MCP servers	Key compromise = persistent access; no rotation; no user context	Short-lived STS tokens or per-user OAuth; automatic rotation via Secrets Manager
Storing OAuth tokens in plaintext	Token exfiltration from storage = unauthorized access to all connected systems	Encrypt tokens at rest with KMS; use HSM for high-value refresh tokens
LLM can read its own token store	Prompt injection could cause LLM to exfiltrate tokens	Tokens inaccessible to LLM layer; only passed by orchestrator to specific tool
Application-level permissions for SharePoint	AI can read all SharePoint content, not just what user can access	Delegated permissions only; OBO flow; user's token passed to Graph
Skipping approval for 'low-risk' AI actions	Scope creep; AI takes actions user didn't explicitly authorise	Define clear privileged action taxonomy; err on side of requiring approval
Single OAuth scope for all GitHub operations	Read token used for write operations by confused AI	Separate scopes per operation type; OPA validates scope matches requested action
No token revocation on employee offboarding	Departed employee's AI sessions continue to operate on their behalf	HR-triggered Entra ID disable; CAE immediately revokes active tokens; Secrets Manager rotation

Summary: Banking Architecture Decision Principles

- Identity: Entra ID as single IdP; ADFS bridge for legacy; no local accounts for AI services
- Authentication: OAuth 2.1 + PKCE everywhere; OBO for multi-hop; JWT Bearer for service identity
- Authorization: OPA with Rego; deny by default; explicit allow per user-role-tool-data combination
- Secrets: AWS Secrets Manager + HashiCorp Vault; automatic rotation; KMS encryption; no static keys
- Audit: 10-step complete audit chain; Splunk ES; CloudTrail; non-repudiable; 7-year retention
- Human Oversight: ServiceNow approval workflows for all privileged actions; Slack bot for speed
- Compliance: OPA policies encode PCI, SOX, MAS TRM rules; automated compliance evidence generation